

bunq Internal Control

Incident Response

Document Control

Field	Value
Document ID	CTRL-INCI-005
Version	1.0
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer / Management Board
Last Reviewed	2026-Q1
Classification	Internal — Restricted
Next Review Due	2027-Q1

1. Purpose

This Standard Operating Procedure defines bunq's process for identifying, classifying, responding to, and recovering from security and operational incidents, including ICT-related incidents, data breaches, and service availability events. The procedure establishes severity tiers, response timelines, escalation paths, regulatory notification obligations, customer communication standards, and post-incident review requirements. It is designed to meet bunq's obligations under the EU Digital Operational Resilience Act (DORA), GDPR Art. 33–34, NIS2 Directive, and DNB operational continuity supervisory expectations as a licensed credit institution.

2. Scope

In scope:

- All ICT-related incidents affecting bunq's production systems, including: payment platform outages, API failures, data integrity events, cybersecurity incidents (malware, ransomware, DDoS, unauthorised access), and fraud system failures.
- Personal data breaches as defined by GDPR Art. 4(12), including accidental disclosure, unauthorised access, and data destruction.
- Incidents at critical third-party ICT service providers (cloud providers, payment processors, identity verification vendors) where bunq is the affected financial entity.
- Operational incidents with potential regulatory reporting obligations under DORA or PSD2.

Out of scope:

- Internal IT service desk tickets not impacting production services or customer data (governed by ITOPS ticketing SLA, ITOPS-001).
- Fraud cases involving individual customer accounts that do not constitute a systemic incident (governed by CTRL-FRAUD-006).

- Business continuity invocations related to physical premises (governed by BCP-002).

3. Roles and Responsibilities

Role	Responsibility
Incident Commander (on-call engineering lead)	Owns incident lifecycle from detection to resolution; coordinates technical response; updates internal status page every 30 minutes during P1/P2 incidents.
CISO	Notified immediately for all P1 incidents; owns regulatory notification decisions for DORA and NIS2 reports; chairs post-mortems.
Data Protection Officer (DPO)	Assesses all incidents for personal data breach criteria; owns GDPR Art. 33 notification to the Dutch Data Protection Authority (AP).
MLRO	Notified for any incident with potential financial crime implications (e.g., unauthorised access to AML/transaction data).
Customer Communications Lead	Drafts and publishes in-app notifications and status page messages; coordinates with Incident Commander on messaging timing.
DNB Liaison (Compliance Officer)	Files DORA major incident initial notification to DNB; manages regulator communications throughout.

4. Procedure

4.1 Incident Detection and Logging

1. Incidents may be detected via automated monitoring alerts (infrastructure metrics, SIEM alerts, fraud detection), third-party notification (cloud provider advisory, CERT alert), customer reports via support, or staff observation.
2. Any member of staff who identifies a potential incident must immediately create an incident ticket in the incident management system (PagerDuty or equivalent) and notify the on-call engineering lead via the designated alerting channel (#incident-response). Time-to-ticket must not exceed 15 minutes from identification.
3. The on-call Incident Commander acknowledges the ticket within 15 minutes of alert and begins initial triage to determine scope and severity.

4.2 Severity Classification

4. All incidents are classified into one of four severity tiers at initial triage, and reclassified if circumstances change:

Severity	Definition	Example
P1 — Critical	Full or near-full service unavailability, active data breach, confirmed unauthorised access to production systems, or any event meeting DORA major incident criteria. Customer impact: large-scale or systemic.	Payment platform down; ransomware on production infra; confirmed customer data exfiltration.
P2 — High	Significant degradation of a core service, or a security event with contained but unresolved scope. Customer impact: substantial but not systemic.	Payment processing latency >10x normal; suspicious access to non-production system; third-party API failure affecting >20% of transactions.
P3 — Medium	Partial service degradation or a security anomaly under investigation, with limited immediate customer impact.	Single product feature unavailable; elevated error rate on non-payment API; potential phishing targeting bunq brand.

Severity	Definition	Example
P4 — Low	Minor technical issue with no or minimal customer impact, or a security observation requiring investigation.	Non-critical scheduled job failure; one-off customer report of app glitch; low-confidence SIEM alert.

4.3 Escalation

5. **P1 incidents:** Incident Commander immediately pages the CISO, Head of Engineering, and CEO. The Compliance Officer (DNB Liaison) is notified within 30 minutes of P1 classification. The MLRO and DPO are notified within 1 hour.
6. **P2 incidents:** CISO notified within 1 hour of classification. DPO notified if any personal data is potentially involved.
7. **P3/P4 incidents:** Managed by on-call engineering; Incident Commander notifies CISO by end of business day.
8. Escalation notifications are sent via a dedicated out-of-band channel (Signal group or encrypted SMS) in addition to Slack/PagerDuty, to ensure reachability during infrastructure outages.

4.4 Regulatory Notification — DORA (Major ICT Incidents)

9. The Incident Commander and CISO jointly assess whether the incident meets DORA major incident criteria per DORA Art. 18, using the DNB-published classification matrix (criteria include: number of customers affected, transaction volume impacted, geographic spread, reputational significance, duration).
10. If the incident meets major incident criteria:
 - **Initial notification to DNB:** Filed within **4 hours** of classifying the incident as major (and no later than 24 hours from first awareness), via the DNB secure notification portal. Content: incident ID, classification date/time, preliminary description, estimated customer impact, services affected, initial containment measures taken.
 - **Intermediate report to DNB:** Filed within **72 hours** of the initial notification, with: updated impact assessment, root cause hypothesis, recovery timeline, and any ongoing risks.
 - **Final report to DNB:** Filed when root cause analysis (RCA) is complete, and in any event no later than **1 month** after the intermediate report. Content: full RCA, permanent remediation steps, lessons learned, control improvements.
11. The DNB Liaison records each notification in the regulatory correspondence log with timestamp, filing reference number, and the identity of the person who made the filing.

4.5 Regulatory Notification — GDPR (Personal Data Breaches)

12. The DPO assesses whether the incident constitutes a personal data breach within the meaning of GDPR Art. 4(12) (accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data).
13. If a personal data breach is confirmed or reasonably suspected:
 - The DPO files a notification to the Dutch Data Protection Authority (AP) via the AP's online breach notification portal within **72 hours** of bung becoming aware of the breach, per GDPR Art. 33.
 - If notification cannot be made within 72 hours, the DPO files a partial notification within the deadline, followed by a supplementary notification as further information becomes available. The reason for any delay is documented.
 - If the breach is likely to result in a high risk to affected individuals' rights and freedoms, the DPO also manages direct customer notification under GDPR Art. 34, in coordination with the Customer Communications Lead.
14. The DPO maintains a breach register per GDPR Art. 33(5) for all breaches, including those not reported to the AP (with documented justification for non-reporting).

4.6 Customer Communication

15. For P1 incidents with customer-visible impact, the Customer Communications Lead publishes an initial status update on bung's in-app status notification and public status page within **30 minutes** of P1 classification. The initial message acknowledges the issue and provides an estimated resolution timeline where known.
16. Status updates are published at minimum every **60 minutes** during an active P1, and every **2 hours** during an active P2, until the incident is resolved.

17. Messages are factual and contain: nature of the impact, affected services, current status (investigating / identified / monitoring / resolved), next update time. Speculative root causes are not disclosed before RCA completion.
18. Where a data breach requires individual customer notification under GDPR Art. 34, the notification is delivered via in-app message (authenticated channel) within 72 hours of the GDPR Art. 33 DPA notification, and includes: description of the breach, categories and approximate number of records affected, DPO contact details, recommended actions for the customer, and the AP complaint channel.

4.7 Containment, Eradication, and Recovery

19. The Incident Commander leads technical containment measures appropriate to the incident type (e.g., isolate affected systems, revoke compromised credentials, enable WAF rules, redirect traffic). All containment actions are logged in the incident timeline in real time.
20. Eradication (removing the root cause) and recovery (restoring normal service) are planned and executed under the Incident Commander's direction, with CISO sign-off required before production systems affected by a security incident are reconnected to the network.
21. The Incident Commander declares the incident resolved when: service metrics have returned to normal baselines for at least 30 minutes; no further anomalous activity is detected; and all containment measures are either permanent or have a documented remediation plan.

4.8 Post-Incident Review (Post-Mortem)

22. A written post-mortem is required for all P1 and P2 incidents and is completed within **5 business days** of incident resolution.
23. The post-mortem is blameless in tone and covers: timeline of events (detection to resolution), root cause analysis, contributing factors, customer and business impact, effectiveness of response, and a prioritised action list with owners and due dates.
24. The CISO reviews the post-mortem and assigns action items. Actions with a potential to prevent future major incidents are escalated to the Management Board monthly CISO report.
25. Post-mortem documents are stored in the compliance document management system and are available to DNB upon request.

4.9 24/7 On-Call Rotation

26. bunq maintains a 24/7 on-call rotation covering: engineering (primary incident response), security (SIEM/SOC), and compliance (MLRO/DPO backup). On-call schedules are published in PagerDuty and reviewed monthly.
27. On-call engineers must acknowledge pages within 15 minutes. Failure to acknowledge escalates automatically to the secondary on-call and then to the engineering manager.
28. Quarterly on-call simulation exercises (tabletop or technical drills) test the full P1 response procedure, including regulatory notification workflows. Results are documented and reviewed by the CISO.

5. Frequency and Triggers

Activity	Frequency / Trigger
Incident ticket creation	Within 15 minutes of detection
P1 DORA initial notification to DNB	Within 4 hours of major incident classification
GDPR Art. 33 notification to AP	Within 72 hours of becoming aware of a personal data breach
Customer in-app status update (P1)	Within 30 minutes, then every 60 minutes

Activity	Frequency / Trigger
DORA intermediate report to DNB	Within 72 hours of initial notification
Post-mortem (P1/P2)	Within 5 business days of resolution
DORA final report to DNB	Within 1 month of intermediate report
On-call drill	Quarterly
Procedure review	Annually; after any P1 post-mortem resulting in process changes

6. Records and Retention

- All incident tickets, including timeline logs, escalation records, containment actions, and resolution notes, are retained for **5 years** from incident resolution date.
- Regulatory notification filings (DORA initial/intermediate/final reports; GDPR Art. 33 notifications) and confirmation receipts are retained for **10 years** from filing date.
- Post-mortem documents are retained for **10 years**.
- The GDPR breach register is retained for **10 years** per GDPR accountability principle.
- On-call drill results and attestation records are retained for **5 years**.
- Records are stored in the compliance document management system, encrypted at rest. Access is restricted to Compliance, Security, Engineering, and Legal functions.

7. References

Regulation	Relevance
EU Regulation 2022/2554 (DORA) Arts. 17–18	ICT-related incident management; major incident classification and reporting
GDPR (EU 2016/679) Arts. 33–34	Personal data breach notification to supervisory authority and data subjects
EU Directive 2022/2555 (NIS2)	Cybersecurity incident reporting for essential and important entities
EBA Guidelines on ICT and Security Risk Management (EBA/GL/2019/04)	ICT incident response baseline standards for credit institutions
DNB Regeling specifieke bepalingen	DNB-specific operational continuity requirements for licensed banks
PSD2 Art. 96 (EU 2015/2366)	Major operational or security incident reporting obligations for payment service providers